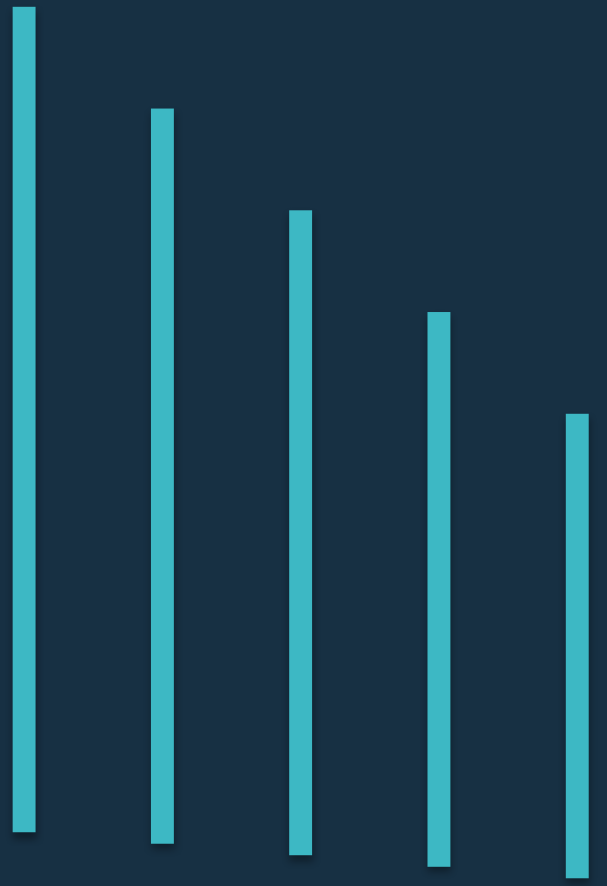
PROYECTO FINAL · APRENDIZAJE POR REFUERZO

WAF Arena

Atacante y defensor que aprenden en un laboratorio SQLi aislado

Diego Valenzuela · Daniel Dubón
Joaquín Puente · Nelson García



La pregunta y las cuatro fases

¿Qué cambia cuando atacante y defensor aprenden dentro del mismo laboratorio?

01

Laboratorio

Aplicación, WAF, oráculo y datos

02

Atacante clásico

Bandits, DP, MC y TD

03

Deep RL

Defensor DQN y atacante PPO

04

Planning + self-play

Dyna, generaciones y prueba final

ER: evasión

TPR: ataques detectados

FPR: benignos marcados

Mismo principio en toda la campaña: selección con validación; test para evaluación final.

Fuente: docs/03-plan/plan-maestro.md · docs/00-vision/vision.md

Un laboratorio aislado que mide efecto real

El oráculo confirma si una inyección modifica la consulta o alcanza canarios.

Agente atacante
Payload SQLi

→

Proxy
Decisión + trazas

→

ModSecurity
PL1 · PL2 · PL3 · PL4

→

Vulnapp + DB
FastAPI · PostgreSQL

Oráculo funcional

Consulta ejecutada + canarios
→ éxito real del payload

Aislamiento

Red Docker interna; sin tráfico hacia sistemas externos.

Datos congelados

train / val / test separados; test fuera del entrenamiento.

Fuente: report/capitulos/03-laboratorio.md · lab/docker-compose.yml

Una misma superficie de ataque, ocho métodos

16 operadores de mutación + acción SEND; cada método elige cómo explorar.

Bandits

greedy, ε-greedy, UCB

Programación dinámica

value / policy iteration

Monte Carlo

first / every visit

TD

SARSA, Q-learning, SARSA(λ)

Protocolo: configuración YAML · semillas explícitas · IC 95 % bootstrap

El defensor aprende decisiones por solicitud

El atacante PPO aporta un oponente entrenado para las evaluaciones posteriores.

Observación del defensor

37 variables: solicitud, scores del WAF, sesión y ventana.

→

DQN

Q(s, acción) para cinco acciones de defensa.

→

Acción

Permitir · bloquear · captcha · limitar · honeypot

Variantes del DQN

Base → Double → Dueling → Prioritized Replay (PER)

Atacante PPO: observación de 288 variables · 16 mutaciones + SEND.

Fuente: report/capitulos/05-deep-rl.md · docs/02-contratos/env-defensor.md

DQN frente a los cuatro niveles de ModSecurity

Compromiso entre detección de ataques y fricción sobre tráfico benigno.

Defensor	TPR	FPR
DQN α = 4	99,84 %	0,02 %
ModSecurity PL1	71,50 %	0,00 %
ModSecurity PL2	97,25 %	0,00 %
ModSecurity PL3	100,00 %	33,27 %
ModSecurity PL4	100,00 %	38,44 %

α = 8 y α = 16 dominan PL1/PL2 con criterio conservador de IC; PL3/PL4 alcanzan 100 % TPR con FPR alto.

Fuente: results/summary/EXP-F5.csv · report/capitulos/05-deep-rl.md

El tráfico benigno difícil revela la fragilidad

La detección sigue alta; el costo aparece en falsos positivos.

Suite del DQN	TPR	FPR
Test estándar	99,84 %	0,02 %
Familias no vistas	100,00 %	0,02 %
Benignos difíciles	99,97 %	33,85 %

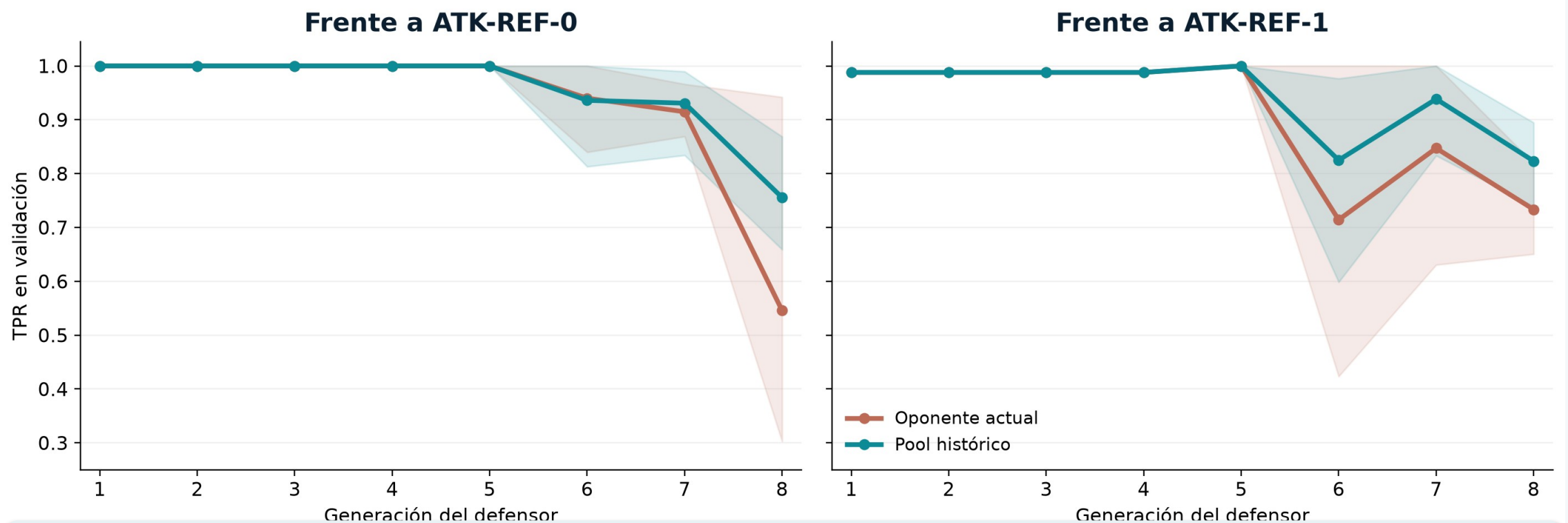
Hallazgo

Una buena TPR en la suite estándar no asegura una tasa baja de falsos positivos fuera de distribución.

Fuente: results/summary/EXP-F6F7_generalization.csv

Ocho generaciones: oponente actual vs. pool

TPR en validación frente a dos atacantes fijos; bandas de IC 95 % sobre tres semillas.



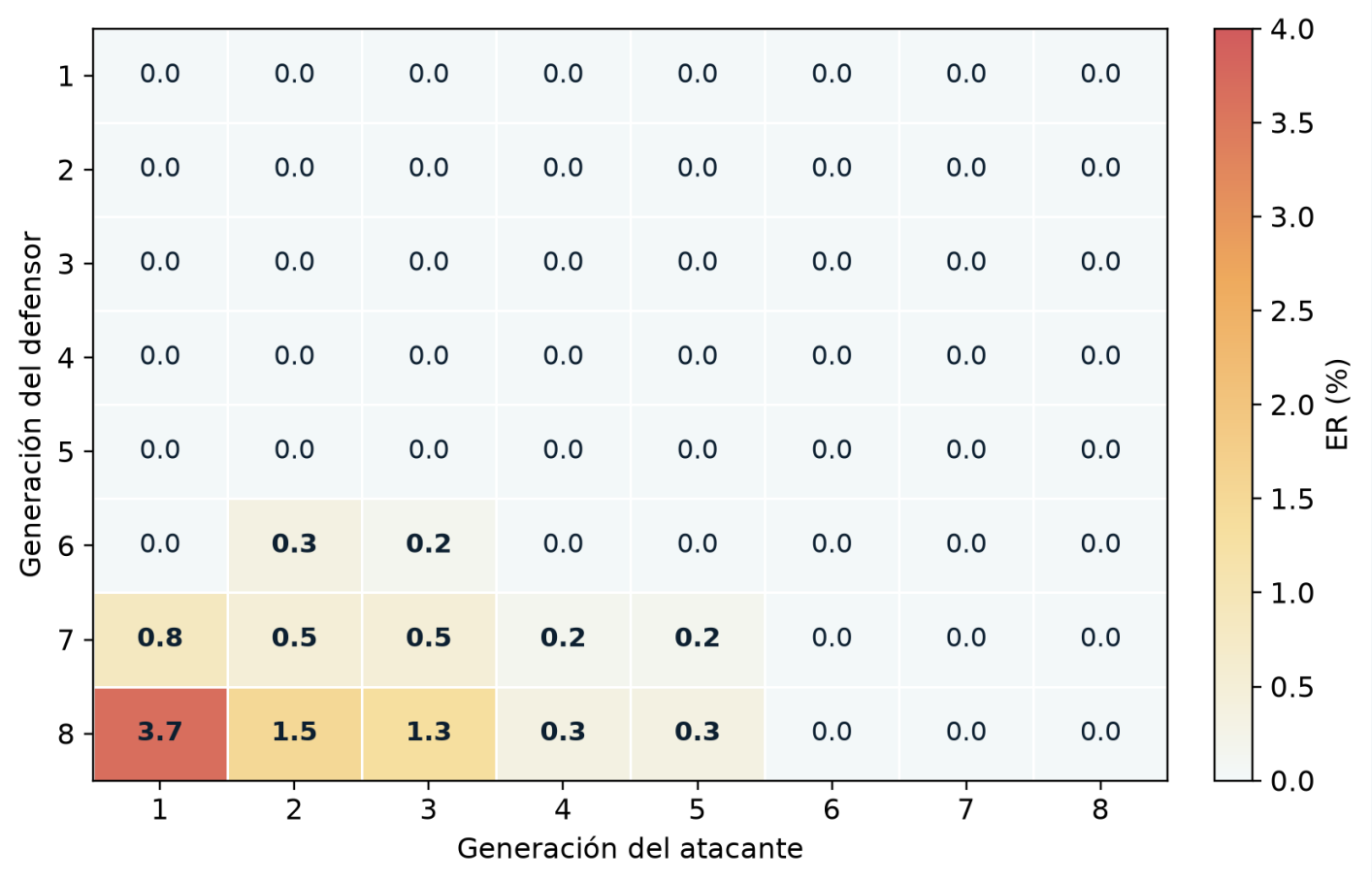
Gen. 8 · ATK-REF-0: 54,58 % → 75,56 % · ATK-REF-1: 73,34 % → 82,34 %

Pool superior al cierre en ambas referencias; los intervalos se superponen.

Fuente: results/summary/EXP-I1_curve.csv · entrenamiento eea6f78

Vulnerabilidades concentradas en generaciones tardías

ER (%) de cada generación defensora frente a cada generación atacante del pool.



59 / 38 400

Evasiones en 192 celdas de evaluación.

3,67 %

Mayor ER media: defensor gen. 8 vs. atacante gen. 1.

Patrón

Todas las evasiones ocurrieron con un defensor más nuevo que el atacante.

Fuente: results/summary/EXP-I2_matrix.csv · test · 3 semillas

FASE 4 · PRUEBA FINAL

El campeón no generaliza a todas las condiciones

Checkpoint seleccionado en validación: def-gen-08, semilla 0. Valores sobre test.

Prueba	Campeón TPR / FPR	DEF-REF-1 TPR / FPR	PL2 TPR / FPR
I3 · familias nuevas	94,46 / 0,12 %	100 / 0,08 %	99,26 / 0 %
I4 · benignos difíciles	96,79 / 40,84 %	100 / 33,47 %	98,46 / 0 %
I5 · PPO no visto	59,16 / 0,12 %	99,90 / 0,08 %	99,75 / 0 %

Límite de I5 · Dyna-5

TPR = 100 % sobre 87 solicitudes emitidas; 127 de 200 sesiones previstas no emitieron ninguna.

Fuente: results/summary/RQ5_final.csv · evaluación bf14912

Conclusiones

01

Defensa fuerte en la suite estándar

DQN compite con los niveles bajos de ModSecurity.

02

Generalización limitada

Tráfico benigno difícil y PPO nuevo degradan el desempeño.

03

La señal del entorno importa

Sin evasiones en el espacio de mutación, planning no aporta ventaja.

¿Preguntas?